

AetherGraph

Parth's Original Build vs. Hardik's Audit and Correction

Personal handover record — 8–12 September 2026

This is a personal handover record, not part of the manuscript's supporting material. The paper's technical record, `PRE_POST_TECHNICAL_RECORD.md`, deliberately does not attribute work to either author. This document does, at the user's request, for their own reference.

Attribution basis. Parth built the implementation up to and including the state recovered from `AetherGraph.rar` (the PRE state below). Hardik performed the forensic audit, the correction, the live validation, and the manuscript work described here. This split was confirmed directly by the user and is not independently verified from repository metadata — the project had no version control before Hardik initialized one, so no commit history distinguishes the two.

All technical facts below are the same facts in `PRE_POST_TECHNICAL_RECORD.md`, cited the same way: PRE claims against the archive-recovered source tree, POST claims against the live repository. Nothing here overrides that document; this is a reframing of it.

1 What Parth Built

A cross-layer security-evidence fusion pipeline: active reconnaissance (Nmap/Gobuster in Docker), identity/OSINT collection, repository secret scanning, manual VAPT report ingestion, and a bounded Nuclei scan, all normalized to JSON Lines, loaded into one NetworkX graph, and scored by a criticality/path-ranking function.

The graph model, the scoring equations

$$CR(v) = 0.40 S(v) + 0.25 R(v) + 0.25 B(v) + 0.10 A(v)$$

(path score = product of edge confidences times sum of node severities times $\lambda^{|\pi|-1}$, $\lambda = 0.95$), the confidence floor (0.60), and the testbed (four Docker containers with deliberately planted evidence) are all Parth's design. **The scoring arithmetic was correct throughout and was never at fault** — the correction did not touch it.

The pipeline produced a working result: 13 nodes, 13 edges, and a top-scoring cross-layer path at **0.914**.

2 What Hardik Found

Auditing that 0.914 result against the collector source (not just the output) turned up three relationships that were not derived from evidence:

1. `collectors/run_secret_scan.py:48` — every repository secret, regardless of type, was linked to `svc-{target_ip}-3000` by a hardcoded literal. The synthetic AWS canary in the testbed was consequently linked to a Gitea service it has no relationship to.

2. `collectors/run_manual.py` — the manual report’s `related_credentials` field was converted directly into a graph edge. The analyst’s own claim was the “discovery.”
3. `collectors/run_identity.py` — every harvested email produced an FTP account edge to port 21, unconditionally, though the testbed’s FTP container is provisioned for a different username entirely.

The first two of these are the two edges that make up the 0.914 path. **The scoring was correct; the graph it was scoring was not.**

A second, independent problem: the traversal walked every edge type as attacker movement, including asset-containment and evidence-lineage relationships that describe structure, not capability. A chain of honestly observed evidence scored **1.354** under that traversal — higher than the fabricated 0.914 path — which shows the semantic defect was not merely cosmetic.

Neither problem was caught by any existing safeguard: the confidence floor, the path-length penalty, the tri-layer predicate, score recomputation, or the unit test suite (which, at the time, included a test asserting the fabricated relationship as correct behaviour).

3 What Hardik Changed

- Added a mandatory **provenance** label to every edge (`observed` / `derived` / `declared`), with required justification for derived edges.
- Rewrote the three collectors above so cross-layer relationships are **derived from evidence and can decline** — a repository secret only links to a service if a real remote, an independently observed service, and a compatible credential type all agree; an account only exists if corroborated; a manual finding links to a service by parsing where the analyst tested, not by naming a graph node.
- Added **endpoint validation** so a malformed record can no longer create an attribute-less phantom node.
- Added an explicit **edge-semantics registry** (`containment` / `evidence` / `validation` / `access` / `correlation`) and restricted attack-path traversal to capability (**ACCESS**) edges only.
- Added a **seed manifest** (expected + forbidden relationships) as a permanent regression check, and a **web-evidence collector** that recovers two genuinely observed cross-layer facts the original pipeline never collected.
- Wrote **74 tests** (up from 8 unique tests in Parth’s version), 35 of them negative — asserting that a rule declines rather than that it succeeds.
- Ran a **live end-to-end execution** against the actual Docker testbed, which reproduced the replay results exactly and, in the process, caught and fixed a genuine error in Hardik’s own replay fixture (an evidence source misattributed to the wrong virtual host) — disclosed rather than silently corrected.
- Ran a **live positive-control experiment** — a real Gitea instance, a real issued access token (verified to authenticate, later revoked), a real repository remote (proven functional by a successful push) — showing the corrected derivation rule does emit a capability relationship, and attack traversal does accept it, when the evidence genuinely exists (score 0.855). Two negative controls, same live credential, confirmed the rule declines when that evidence is removed.
- Rewrote the manuscript from a results paper into a failure-analysis paper, with every quantitative claim cross-checked against generated artifacts and hostile-reviewer-audited language

throughout.

4 Numbers, Side by Side

	Parth's version (PRE)	After Hardik's correction (POST)
Graph	13 nodes, 13 edges	14 nodes, 13 edges
Edge provenance	none recorded	9 observed / 3 derived / 1 declared
Capability (ACCESS) edges	3 (all fabricated or analyst-declared)	0 in the replay/live graph; 1 genuine, live-validated in a separate positive control
Top cross-layer result	2 paths, top score 0.914, presented as an attack finding	0 attack paths; the 0.914 result reclassified as an unsupported evidence path
Tests	11 discovered (8 unique; one duplicate file); 2 of them asserted the fabricated relationships as correct	74 passing, 35 negative
Live validation	none	full live end-to-end run + live positive control, both confirmed

5 What Did Not Change

Parth's scoring equations, the criticality formula, the testbed design, and the core idea — fuse heterogeneous evidence into one graph and rank paths — are unmodified. The correction is entirely in graph *construction* and *traversal semantics*, not in the mathematics. This is stated explicitly in the paper's own account (Section “Corrected Architecture”: “*The scoring of Section ?? is unchanged: the arithmetic was never at fault.*”).

Generated as a PDF for personal reference. See PRE_POST_TECHNICAL_RECORD.md for the full, non-attributional, artifact-cross-checked version of this same material, and paper.pdf for the manuscript.